

Cyber Security - APM Trusted Insider Program

1. Introduction

1.1 Background

The protection of Advanced Personnel Management (APM) Information Assets and systems is a basic business requirement, as well as a contractual and legal obligation which APM takes extremely seriously.

A trusted insider's access to systems and knowledge of business processes can often make detecting threats harder to detect. To mitigate this risk, APM has established a Trusted Insider Program to implement controls which can assist in the detection and response of trusted insider threats before they occur or limit damage if they do occur.

1.2 Purpose

The purpose of this document is to detail the controls and processes within APM that are implemented to mitigate trusted insider threats.

2. Trusted Insiders

APM consider the following user types to be Trusted Insiders:

- IT System Administrators
- IT Developers
- Database Administrators
- Executives
- General Managers or above
- Finance Dept staff
- Any user with elevated permissions or access to APM data.

3. Additional Controls

3.1 Training

A dedicated training programme based on job role is implemented for trusted insiders. Examples include:

- Invoice fraud for Finance dept
- Security training for IT Developers
- CEO Fraud for Executives

Increased phishing awareness training campaigns targeted at all trusted insiders.

3.2 Identity and Access Management

Staff that perform privileged administration tasks using separate accounts which have the trusted insider and additional privileged account protections applied to them.

Additional password complexity is applied to all trusted insider privileged accounts.

Contractors are subject to the same level of controls as APM staff.

3.3 Additional System Access

IT Trusted Users are provisioned access to an enterprise password management solution.

3.4 Logging and Monitoring

Trusted Insiders are identified, and protective monitoring is in place via the external Security Operations Centre.

Logging will include:

- Authentication events
- Endpoint protection alerts
- Internet browsing activity

Monitoring will include:

- Microsoft Purview Insider Risk Management

4. Review

Update this document whenever requirements change and review at least once a year.

5. Definitions

Term	Definition / Explanation / Details
CEO	Chief Executive Officer
Information Assets	An information asset is a body of information that has financial value to an organization.